CENTRO PAULA SOUZA

ETEC ANTÔNIO FURLAN

Informática Para Internet

Piettro Xavier de Souza

ROTEIRO DE TESTES BACKEND

BARUERI

2026

Piettro Xavier de Souza

ROTEIRO DE TESTES BACKEND

Trabalho de conclusão parcial de curso realizado para aprovação no componente Planejamento e Desenvolvimento do Trabalho de Conclusão de Curso (TCC) em Informática para Internet da 3° série do ensino médio, submetido a ETEC Antônio Furlan

Professor(a) Orientador(a): Wagner Gusmão

BARUERI

2026

“Família, perdi o pendrive com a IA”

(FITIPALDI, Thiago)

Resumo

Este documento apresenta um roteiro de testes de backend para uma aplicação de gestão de usuários, setores, equipes e projetos, utilizando requisições HTTP e envio de objetos JSON por ferramentas como Insomnia e Thunder Client. O roteiro contempla procedimentos de autenticação por meio de tokens JWT, criação e gestão de usuários, atribuição de funções e permissões, recuperação de senha por e-mail e gerenciamento de projetos. São abordadas operações de criação, edição, aprovação, rejeição, versionamento, inativação e consulta de projetos, bem como a consulta dos respetivos registos de atividade. O documento também estabelece uma matriz de permissões para diferentes perfis de usuário e apresenta testes negativos destinados a verificar a recusa de operações não autorizadas. A sequência dos procedimentos considera as dependências entre os recursos e os efeitos de exclusão em cascata, recomendando a utilização de um ambiente de testes com dados fictícios. Adicionalmente, são identificadas melhorias futuras, como a implementação de filtros para consulta de registos e a limitação dos resultados de acordo com o setor e a equipa do usuário autenticado. Dessa forma, o roteiro procura padronizar os procedimentos de teste e facilitar a verificação das funcionalidades e dos mecanismos de controlo de acesso do backend.

Palavras-chave: Testes de backend; Autenticação JWT; Controlo de acesso; Gestão de usuários; Gestão de projetos.

Abstract

This document presents a backend testing guide for an application that manages users, departments, teams and projects, using HTTP requests and JSON payloads through tools such as Insomnia and Thunder Client. The guide covers JWT-based authentication, user creation and management, role and permission assignment, email-based password recovery, and project management. The procedures include project creation, editing, approval, rejection, versioning, deactivation and retrieval, as well as access to the corresponding activity logs. The document also defines a permission matrix for different user roles and outlines negative authorisation tests designed to verify that unauthorised operations are rejected. The testing sequence takes account of dependencies between resources and the effects of cascading deletion, recommending the use of a test environment with fictitious data. In addition, the guide identifies planned improvements, including filtering activity logs by action and restricting project and log queries according to the authenticated user's department and team. Overall, the guide aims to standardise testing procedures and facilitate the verification of backend functionality, access control and authorisation mechanisms.

Keywords: Backend testing; JWT authentication; Access control; User management; Project management.

SUMÁRIO

1. INTRODUÇÃO 7
2. CRIAR E DELETAR SETOR (Sectors) 8
2.1 Criação de setor 9
2.2 Deletando setor 9
3. CRIAR E DELETAR EQUIPE (teams) 9
3.1 Criação de time 10
3.2 Deletando time 10
4. CRIAR USUÁRIO (users/register) 10
4.1 Criação de usuário comum 11
4.2 Criação de usuário aprovador 11
5. FAZER LOGIN (users/login) 11
5.1 Login do usuário comum 12
5.2 Login do usuário aprovador 12
6. CRIAR, CONSULTAR, ALTERAR E REMOVER FUNÇÕES (users-role) 12
6.1 Vincular usuário comum a setor e equipe 13
6.2 Vincular usuário aprovador a setor e equipe 13
6.3 Consultar vínculos de usuários 14
6.4 Alterar vínculos de usuários 14
6.5 Remover vínculos de usuários 15
7. CONSULTAR, EDITAR E DESATIVAR USUÁRIOS (users/management) 15
7.1 Consultar usuários 16
7.2 Alterar dados de usuários 16
7.3 Atribuição de head-manager 16
7.4 Desativar usuário (soft delete) 17
8. REDEFINIÇÃO DE SENHA POR E-MAIL (users/password-reset) 17
8.1 Solicitar redefinição 18
8.2 Realizar redefinição 18

9. CRIAR, EDITAR, APROVAR / REJEITAR, VERSIONAR, INATIVAR E CONSULTAR PROJETOS (projects) 19
9.1 Criar rascunho 20
9.2 Editar rascunho 21
9.3 Aprovar rascunho 22
9.4 Rejeitar rascunho 23
9.5 Criar nova versão de um projeto 23
9.6 Desativar projeto 24
9.7 Consultar projetos 24
10. CONSULTAR LOGS DE PROJETOS (projects-logs) 25
11. MATRIZES DE PERMISSÃO 26
11.1 Regras de permissão e escopo 27
11.2 Testes negativos de autorização 27
12. CONCLUSÃO 28

1. INTRODUÇÃO

O presente documento possui o principal fluxo de testes de backend, com requisições sendo feitas diretamente por ferramentas como *ThunderClient* ou *Insomnia* através do envio de JSONs. Para melhor proveito dos testes, siga as instruções abaixo:

- Execute preferencialmente em ambiente de teste, com dados fictícios;
- Garanta que exista um usuário ativo com head-manager=true (criado diretamente no banco de dados);
- Testes de “Delete” deverão ser realizados após demais testes;
- O documento segue sequência lógica para testes, ou seja, não seguir a ordem apresentada pode acarretar o não funcionamento de determinadas funções.

Antes de iniciar os testes, faça login com o usuário com head-manager=true: POST http://localhost:3000/login

```
{
  "login": "headmanager@gmail.com",
  "password": "senha123"
}
```

Após login bem-sucedido, guarde o token JWT gerado, ele será utilizado para funções que não podem ser realizadas por qualquer usuário.

Obs: Ao final do documento se farão presentes os tipos de permissão de cada usuário.

2. CRIAR E DELETAR SETOR (Sectors)

2.1 Criação de setor

POST http://localhost:3000/sectors

Para a criação de setor, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Tecnologia e Inovação"
}
```

Após criação, salve o ID do setor.

2.2 Deletando setor

DELETE http://localhost:3000/sectors/*ID do setor*

Para a exclusão de setor, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Após a remoção, efeitos de *cascade* irão excluir times, projetos e demais relacionados.

3. CRIAR E DELETAR EQUIPE (teams)

3.1 Criação de time

POST http://localhost:3000/teams

Para a criação de time, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Desenvolvimento de Sistemas",
  "sector": "*ID do Setor*"
}
```

Após criação, salve o ID do time.

3.2 Deletando time

DELETE http://localhost:3000/teams/*ID do time*

Para a exclusão de time, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Após a remoção, efeitos de *cascade* irão excluir projetos e demais relacionados.

4. CRIAR USUÁRIO (users/register)

4.1 Criação de usuário comum

POST http://localhost:3000/register

Para a criação de usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Comum",
  "email": "comum@gmail.com",
  "password": "comum123",
  "cpf": "12345678910"
}
```

Após criação, salve o ID do usuário.

4.2 Criação de usuário aprovador

POST http://localhost:3000/register

Para a criação de usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Aprovador",
  "email": "aprovador@gmail.com",
  "password": "aprovador123",
  "cpf": "10987654321"
}
```

Após criação, salve o ID do usuário.

5. FAZER LOGIN (users/login)

5.1 Login do usuário comum

POST http://localhost:3000/login

```
{
  "login": "comum@gmail.com",
  "password": "comum123"
}
{
  "login": "12345678910",
  "password": "comum123"
}
```

Após criação, salve o token JWT do usuário.

5.2 Login do usuário aprovador

POST http://localhost:3000/login

```
{
  "login": "aprovador@gmail.com",
  "password": "aprovador123"
}
{
  "login": "10987654321",
  "password": "aprovador123"
}
```

Após criação, salve o token JWT do usuário.

6. CRIAR, CONSULTAR, ALTERAR E REMOVER FUNÇÕES (users-role)

6.1 Vincular usuário comum a setor e equipe

POST http://localhost:3000/users-role

Para a vinculação de usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "user": "*ID do usuário comum*",
  "sector": "*ID do setor*",
  "team": "*ID do time*",
  "sector_manager": false,
  "team_manager": false,
  "team_approver": false
}
```

Após criação, salve o ID da vinculação.

6.2 Vincular usuário aprovador a setor e equipe

POST http://localhost:3000/users-role

Para a vinculação de usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "user": "*ID do usuário aprovador*",
  "sector": "*ID do setor*",
  "team": "*ID do time*",
  "sector_manager": false,
  "team_manager": false,
  "team_approver": true
}
```

Após criação, salve o ID da vinculação.

6.3 Consultar vínculos de usuários

GET http://localhost:3000/users-role

Para a verificação de funções, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

OBS: Em testes com tokens de sector-manager ou team-manager, os retornos devem ser, respectivamente, referentes aos usuários do setor e do time. Um usuário comum não consegue ver funções de outros funcionários.

6.4 Alterar vínculos de usuários

PATCH http://localhost:3000/users-role/*ID do vínculo (users-roles)*

Para a alteração da vinculação, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "team_manager": true
}
```

Após isso, consulte no banco se o vínculo foi alterado.

6.5 Remover vínculos de usuários

DELETE http://localhost:3000/users-role/*ID do vínculo do usuário(users-roles)*

Para a remoção da vinculação, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Essa ação exclui apenas a linha presente em "users-roles", usuário e outros relacionados não são afetados.

7. CONSULTAR, EDITAR E DESATIVAR USUÁRIOS (users/management)

7.1 Consultar usuários

GET http://localhost:3000/management

Para a consultar usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Teste filtrar usuários por informação específica, como:

```
?email=comum@gmail.com
```

7.2 Alterar dados de usuários

PATCH http://localhost:3000/management/*ID do usuário*

Para a consultar usuário, insira o token do usuário que será editado na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "current_password": "comum123",
  "name": "Usuario Comum - Alterado",
  "email": "usuario.comum.teste.2026@gmail.com",
  "photo": null
}
```

Obs: CPF é único e imutável para o sistema, sendo unicamente atualizado diretamente no banco de dados.

7.3 Atribuição de head-manager

PATCH http://localhost:3000/management/*ID do usuário*

Para a atribuição de head-manager, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "current_password": "senha123",
  "head_manager": true
}
```

Obs: essa ação se restringe a usuários com head-manager = true, nenhum outro usuário possui permissão para atribuir esta máxima a outro ou a si mesmo.

7.4 Desativar usuário (soft delete)

DELETE http://localhost:3000/management/*ID do usuário*

Para deletar um usuário, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "password": "senha123"
}
```

Obs: usuário não é excluído do banco de dados, apenas seu status é alterado para false; após exclusão, tente fazer login com o perfil deletado para confirmar funcionalidade.

8. REDEFINIÇÃO DE SENHA POR E-MAIL (users/password-reset)

8.1 Solicitar redefinição

POST http://localhost:3000/password-reset/forgot-password

```
{
  "email": "aprovador@gmail.com"
}
```

Resposta genérica usada para não acusar se e-mail existe ou não na base de dados.

Para realizar a redefinição da palavra passe, acesse o e-mail enviado por " Equipe Apresentações Inteligentes Barueri", que irá conter o link para redefinição (página frontend).

8.2 Realizar redefinição

POST http://localhost:3000/password-reset/reset-password

```
{
  "token": "*token de reset*",
  "newPassword": "novaSenha123"
}
```

Token de reset com validade de 30 minutos estará disponível na URL do hyperlink enviado, marcado como "?token=", copie e cole apenas o que estiver após o sinal de igualdade (=)

Obs: o token segue válido por 30 minutos mesmo que outro seja requisitado durante esse período, ação tomada a fim de reduzir a base de dados.

9. CRIAR, EDITAR, APROVAR / REJEITAR, VERSIONAR, INATIVAR E CONSULTAR PROJETOS (projects)

9.1 Criar rascunho

POST http://localhost:3000/projects

Para a criar rascunho, insira o token de qualquer usuário que esteja vinculado ao time do projeto, sendo approver=false na equipe, na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Projeto de Tecnologia",
  "user": "*ID de usuário responsável (referente ao token)*",
  "team": "*ID do time dono do projeto*",
  "family": 0,
  "short_description": "Descricao curta do projeto",
  "full_description": "Descricao completa do projeto",
  "source": ["https://barueri.sp.gov.br", "https://www.gov.br"],
  "main_department": "Secretaria de Educacao",
  "related_departments": ["Secretaria de Educacao"],
  "areas": ["Tecnologia"],
  "ods": [1, 2],
  "theme": "Educacao e Tecnologia",
  "audience": "Alunos e Professores",
  "technologies": ["React", "NestJS", "PostgreSQL"],
  "implementation_date": "2026-09-04",
  "awards": [
    {
      "institution": "Premio de Inovacao",
      "year": 2026,
      "description": "Premio de inovacao tecnologica",
      "link": "https://exemplo.com"
    }
  ],
  "indicators": [
    {
      "label": "Usuarios atendidos",
      "value": "1000",
      "measure": "pessoas",
      "source": "Secretaria de Educacao",
      "year": 2026
    }
  ],
  "keywords": ["educacao", "tecnologia"]
}
```

Após a criação do primeiro projeto, espera-se: status=1; family=id do projeto.

Salve o ID do projeto e o ID da família para testes posteriores.

9.2 Editar rascunho

PATCH http://localhost:3000/projects/*ID do projeto*

Para editar um rascunho, insira o token do usuário responsável pelo projeto na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Projeto de Tecnologia - Editado",
  "user": "*ID de usuário responsável*",
  "team": "*ID do time dono do projeto*",
  "family": 0,
  "short_description": "Descricao curta editada",
  "full_description": "Descricao completa editada",
  "source": ["https://barueri.sp.gov.br"],
  "main_department": "Secretaria de Educacao",
  "related_departments": ["Secretaria de Educacao"],
  "areas": ["Tecnologia"],
  "ods": [1, 2],
  "theme": "Educacao e Tecnologia",
  "audience": "Alunos e Professores",
  "technologies": ["React", "NestJS"],
  "implementation_date": "2026-09-04",
  "awards": [],
  "indicators": [
    {
      "label": "Usuarios atendidos",
      "value": "1200",
      "measure": "pessoas",
      "source": "Secretaria de Educacao",
      "year": 2026
    }
  ],
  "keywords": ["educacao", "tecnologia"]
}
```

Projeto deve manter inalterados: ID, equipe, família, versão e status.

Last_update deve ser alterada e log "editou" deve ser gerado.

Obs: Não é possível criar uma nova versão de um projeto (atribuir a mesma família) enquanto status=1, ou seja, rascunho é único na família.

9.3 Aprovar rascunho

PATCH http://localhost:3000/projects/*ID do projeto*/approve

Para aprovar um rascunho, insira o token de aprovador do time na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Status agora deve ser 2; last_update deve ser atualizado e log “aprovou” deve ser gerado.

9.4 Rejeitar rascunho

DELETE http://localhost:3000/projects/*ID do projeto*/reject

Para rejeitar um rascunho, insira o token de aprovador do time na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

O projeto será excluído da base de dados; awards, indicators e projects_logs vinculados serão excluídos por *cascade*.

9.5 Criar nova versão de um projeto

POST http://localhost:3000/projects

Para criar uma nova versão, insira o token de qualquer usuário que esteja vinculado ao time do projeto, sendo approver=false na equipe, na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

```
{
  "name": "Projeto de Tecnologia - Versao 2",
  "user": "*ID do usuário responsável (referente ao token)*",
  "team": "*ID do time dono do projeto*",
  "family": "*ID da família a qual versão pertence*",
  "short_description": "Descricao curta da versao 2",
  "full_description": "Descricao completa da versao 2",
  "source": ["https://barueri.sp.gov.br", "https://www.gov.br"],
  "main_department": "Secretaria de Educacao",
  "related_departments": ["Secretaria de Educacao"],
  "areas": ["Tecnologia"],
  "ods": [1, 2, 3],
  "theme": "Educacao e Tecnologia",
  "audience": "Alunos e Professores",
  "technologies": ["React", "NestJS", "PostgreSQL", "TypeScript"],
  "implementation_date": "2026-09-04",
  "awards": [],
  "indicators": [],
  "keywords": ["educacao", "tecnologia", "inovacao"]
}
```

Obs: family = ID do primeiro projeto

Versão deve ser criada com version=2 e status=1 (rascunho).

Para criar uma nova versão, a versão anterior NÃO deve ser rascunho (status=1)

9.6 Desativar projeto

PATCH http://localhost:3000/projects/*ID do projeto*/deactivate

Para desativar um projeto, insira o token de aprovador do time na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Status agora devera ser 3; log “inativou” deverá ser criado.

Obs: apenas projetos com status=2 (aprovado) poderãos ser inativados, projetos com status=1 (rascunho) apenas poderão ser excluídos.

9.7 Consultar projetos

GET http://localhost:3000/projects

Para consultar projetos, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Teste filtrar projetos por informação específica, como:

```
?id=1

?keywords=educacao,tecnologia
```

Para mesclar filtros, use "?" apenas no início, adicione "&" para utilizar 2 ou mais filtros

Obs: "," é usada para pesquisar arrays que contenha os 2 valores simultaneamente (and); Token define quais projetos poderão ser visualizados:

- Head-manager: pode visualizar todos os projetos;
- Sector-manager: visualiza apenas projetos do próprio setor e dos times nele presentes;
- Team-manager: pode ver apenas projetos do próprio time;
- Demais usuários: veem apenas os projetos pelos quais são responsáveis.

10. CONSULTAR LOGS DE PROJETOS (projects-logs)

GET http://localhost:3000/projects-logs

Para consultar projetos, insira o token de head-manager na ferramenta de testes:

- Insomnia: Auth -> Bearer Token -> Token.

Teste filtrar projetos por informação específica, como:

```
?user=1
```

Obs: Token define quais logs de projetos poderão ser visualizados:

- Head-manager: pode visualizar todos os logs de projetos;
- Sector-manager: visualiza apenas logs de projetos do próprio setor e dos times nele presentes;
- Team-manager: pode ver apenas logs de projetos do próprio time;
- Demais usuários: veem apenas os logs de projetos alterados por eles.

11. MATRIZES DE PERMISSÃO

11.1 Regras de permissão e escopo

Indicação as permissões referentes a operações realizadas em times e setores:

Operação	Quem pode executar	Negativa esperada
Criar usuário / desativar usuário	head_manager	demais perfis: 403
Criar setor	head_manager	demais perfis: 403
Vincular/remover pessoas de qualquer setor/equipe	head_manager	gestor fora do escopo: 403
Atribuir/remover sector_manager	head_manager	demais perfis: 403
Criar equipe no próprio setor	head_manager ou sector_manager daquele setor	sector_manager fora do setor: 403
Vincular/remover pessoas em equipes do próprio setor	head_manager ou sector_manager daquele setor	sector_manager fora do setor: 403
Atribuir/remover team_manager	head_manager ou sector_manager do setor	team_manager/usuário comum: 403
Atribuir/remover team_approver	head_manager, sector_manager do setor ou team_manager da equipe	usuário comum ou gestor fora do escopo: 403
Vincular/remover pessoas da própria equipe	head_manager, sector_manager do setor ou team_manager da equipe	gestor de outra equipe: 403

11.2 Testes negativos de autorização

Validação de operações permitidas e recusas foras de escopo:

Teste	Token	Resultado esperado
Criar setor	head_manager	Permitido
Criar setor	usuário comum	403
Criar usuário	head_manager	Permitido
Criar usuário	sector_manager	403
Criar equipe no próprio setor	sector_manager	Permitido
Criar equipe fora do próprio setor	sector_manager	403
Atribuir/remover sector_manager	head_manager	Permitido
Atribuir/remover team_manager	head_manager ou sector_manager do setor	Permitido
Atribuir/remover team_approver	head_manager, sector_manager do setor ou team_manager da equipe	Permitido
Alterar head_manager	head_manager	Permitido
Alterar head_manager	qualquer perfil sem head_manager	403
Consultar todos os users-role	head_manager	Todos os escopos
Consultar users-role	sector_manager	Somente próprio setor
Consultar users-role	team_manager	Somente própria equipe
Desativar usuário	head_manager	Permitido
Desativar usuário	sector_manager	403
Acessar rota protegida sem token	sem Authorization	401
Acessar rota protegida com token inválido/expirado	token inválido	401

12. CONCLUSÃO

O desenvolvimento deste roteiro de testes permite organizar e padronizar os procedimentos de verificação das funcionalidades do backend, abrangendo desde a autenticação e a gestão de usuários até o controlo de permissões e o ciclo de vida dos projetos. A definição de requisições, dados de entrada e resultados esperados facilita a execução dos testes e a identificação de comportamentos incompatíveis com as regras estabelecidas. A inclusão de testes negativos de autorização também contribui para verificar se as operações são restritas aos perfis com permissões adequadas.

A sequência proposta destaca a importância de respeitar as dependências entre os recursos e de executar operações destrutivas somente após a conclusão dos demais testes. Além disso, a documentação identifica funcionalidades que ainda necessitam de melhorias, nomeadamente a filtragem dos registos de atividade e a limitação das consultas de projetos e logs de acordo com o âmbito de atuação de cada usuário.

Por se tratar de um roteiro de testes, e não de um relatório de resultados obtidos, a confirmação do funcionamento esperado depende da execução efetiva dos procedimentos e da análise das respostas da API. Assim, o documento constitui uma base para a avaliação sistemática do backend, permitindo identificar falhas, verificar as regras de autorização e orientar futuras melhorias na segurança e na organização do sistema.